FOODTRUCKAPP · SPRINT 4

Static Analysis Report

Automated review of the FoodtruckApp codebase for defects, security weaknesses and maintainability, covering both the application source and its third-party dependencies.

REPOSITORY	BRANCH	DATE
Unuvert1/FoodtruckApp	**feature/sprint-4-pos-sales**	**5 November 2026**

SCANNED

212 files · 19,030 lines

0	0	54	2	12
BUGS	VULNERABILITIES IN OUR CODE	CODE SMELLS	SECURITY HOTSPOTS	DEPENDENCY ADVISORIES

Unubileg & Jovanni Maya · Software Engineering 1

Tools: SonarSource SonarJS 3.0.7 · Trivy 0.76.0

1. Tools used

Languages analysed	TypeScript and TSX (Next.js 15 App Router, React 19), plus Prisma schema and SQL migrations for the dependency scan
Static analyser	**SonarJS 3.0.7** — SonarSource's own JavaScript/TypeScript rule engine, the same analyser SonarQube runs for this language, executed through ESLint 9 rather than a SonarQube server
Rule set	`sonarjs/recommended`, 269 rules, reported against their SonarSource RSPEC identifiers (S1135, S3358, ...)
Dependency scanner	**Trivy 0.76.0**, filesystem scan (`trivy fs`), vulnerability scanner
Dependency graph	Resolved from `package-lock.json`, so transitive packages are included, not just direct ones
Where executed	Locally on the developer workstation (Windows 11, Node 24), against the working tree of `feature/sprint-4-pos-sales`

> SonarJS is the analyser itself rather than a hosted SonarQube instance. The findings and rule identifiers are the same; what a server would add is a stored history and a Quality Gate evaluated for us. The gate below is therefore assessed against the published "Sonar way" conditions rather than returned by a server.

2. Required metrics

SonarJS — application source

0	0	54	2
BUGS	VULNERABILITIES	CODE SMELLS	SECURITY HOTSPOTS

Rule	RSPEC	Type	Count	Sprint 3	Change
Nested ternary operator `no-nested-conditional`	S3358	Code Smell	33	24	+9
Use of the void operator `void-use`	S3735	Code Smell	6	4	+2
Function too complex `cognitive-complexity`	S3776	Code Smell	6	5	+1
Unresolved TODO comment `todo-tag`	S1135	Code Smell	5	8	-3
Nested template literal `no-nested-template-literals`	S4624	Code Smell	4	4	no change
Regex vulnerable to backtracking `slow-regex`	S5852	Security Hotspot	2	2	no change
Total			56	47	+9

Quality Gate — assessed against "Sonar way"

Condition	Threshold	Measured	Result
Bugs on new code	0	`0`	PASS
Vulnerabilities on new code	0	`0`	PASS
Security hotspots reviewed	100%	`2 of 2`	PASS
Maintainability rating on new code	A	`A (no blocker smells)`	PASS

Quality Gate: PASSED

Trivy — dependencies

0	5	5	2
CRITICAL	HIGH	MEDIUM	LOW

Severity	Sprint 4	Sprint 3	Change
CRITICAL	0	0	no change
HIGH	5	8	-3
MEDIUM	5	6	-1
LOW	2	0	+2
Total	12	14	-2

3. Scope

Scanned	All first-party TypeScript and TSX: 212 files, 19,030 lines — application routes, React components, server actions, and the shared library (pricing, orders, scheduling, geocoding, payments, tenancy)
Also scanned	Every npm dependency in `package-lock.json`, direct and transitive
Excluded	`lib/generated/**` (Prisma client, machine-generated), `node_modules/**`, `.next/**` (build output), `docs/**`, and tool config files
Not covered	No dynamic analysis, no penetration testing, no runtime profiling. Trivy's secret and misconfiguration scanners were not run this sprint; the vulnerability scanner was.

> The exclusions are all machine-generated or third-party output. Analysing the generated Prisma client would report on code neither developer wrote and cannot change.

4. Trend

Measure	Sprint 3	Sprint 4	Change
Lines of first-party code	15,243	19,030	+3,787
SonarJS issues	47	56	+9
SonarJS issues per 1,000 lines	3.08	2.94	−0.14
Security hotspots	2	2	no change
Dependency advisories	14	12	-2
of those, HIGH	8	5	-3

Dependencies improved because we acted on last sprint's plan. Sprint 3's report named two fixes and both were made in the first half of this sprint rather than on the last day: `shadcn` moved from `dependencies` to `devDependencies`, which takes its whole transitive tree off the shipped surface, and Next.js went from 15.5.25 to 15.5.29. Together those cleared six advisories, including every HIGH in `@modelcontextprotocol/sdk`, `braces` and `sharp`. Four new `fast-uri` advisories appeared under `prisma` and `shadcn`, both now development-only.

Source issues rose in absolute terms and fell in density. The codebase grew by 25% this sprint — counter sales, repeating stops, an orders screen, notification emails and an entire marketing site — while issues rose by 19%. Per thousand lines that is 3.08 down to 2.94. Unresolved TODOs fell from 8 to 5. Nested ternaries account for 33 of the 56 findings and for almost all of the increase.

5. Reflection

The most problematic area is nested conditional expressions: 33 of 56 findings, up from 24, and concentrated in the React components that pick what to render from several pieces of state at once — the POS screen alone has six. They are not defects and none has caused a bug, but a three-deep ternary inside JSX is genuinely hard to read, and these are the files we edit most often during a service.

The plan for Sprint 5 is to lift that logic out of the markup in the worst three files (`pos-screen.tsx`, `stop-sheet.tsx`, `order-detail-actions.tsx`), replacing the nested ternaries with a small named variable or an early return per decision, and to close the five remaining TODOs — four of which are the Stripe refund path we have already scheduled. On dependencies, the only advisories still reaching production are `postcss` and `source-map-js`, which Next.js pins inside itself and we cannot move without an override that risks the build, so we will take them with the next Next.js release rather than force them.

This static analysis was generated using automated tools during this sprint.

Appendix A — Dependency advisories in full

Severity	Package	Installed	Fixed in	Advisory	Reaches production?
HIGH	deepmerge-ts	7.1.5	8.0.0	CVE-2026-40345	dev only
HIGH	mysql2	3.15.3	3.22.0	GHSA-3f6p-5ww8-9rcr	dev only
HIGH	postcss	8.4.31	8.5.12	CVE-2026-45623	yes
HIGH	postcss	8.4.31	8.5.18	CVE-2026-73646	yes
HIGH	source-map-js	1.2.1	1.2.2	CVE-2026-93749	yes
MEDIUM	fast-uri	3.1.8	2.4.8, 3.1.9, 4.2.3	CVE-2026-110180	dev only
MEDIUM	fast-uri	3.1.8	2.4.8, 3.1.9, 4.2.3	CVE-2026-110306	dev only
MEDIUM	mysql2	3.15.3	3.23.1	GHSA-rgwj-5xj2-c3m3	dev only
MEDIUM	postcss	8.4.31	8.5.10	CVE-2026-41305	yes
MEDIUM	postcss	8.4.31	8.5.23	CVE-2026-69153	yes
LOW	fast-uri	3.1.8	2.4.8, 3.1.9, 4.2.3	CVE-2026-110095	dev only
LOW	fast-uri	3.1.8	2.4.8, 3.1.9, 4.2.3	CVE-2026-110725	dev only

> **Why the "dev only" column matters.** `deepmerge-ts`, `mysql2` and `fast-uri` all arrive under `prisma` and `shadcn`, which are `devDependencies` — they run on a developer's machine and are never shipped to the server or the browser. `postcss` and `source-map-js` are pinned inside Next.js itself. `mysql2` is also unreachable in practice: this project uses PostgreSQL.

Appendix B — Source findings by file

File	Findings
components/dashboard/pos/pos-screen.tsx	6
components/dashboard/schedule/stop-sheet.tsx	5
components/dashboard/order-detail-actions.tsx	3
components/storefront/menu-list.tsx	3
app/(platform)/invite/[token]/page.tsx	2
app/(storefront)/[truckSlug]/page.tsx	2
components/dashboard/new-order-chime.tsx	2
components/dashboard/orders-browser.tsx	2

Security hotspots, reviewed

Location	Rule	Review
components/dashboard/onboarding-form.tsx:25	S5852	Safe. The subject is a truck name capped at 80 characters from a signed-in vendor, and the result is truncated to 40.
lib/money.ts:71	S5852	Safe. The subject is `bps % 100`, always a two-character string, so there is nothing for the pattern to backtrack over.

> Both hotspots were reviewed by reading the code and the data reaching each pattern, not by suppressing the rule. Both were present and reviewed in Sprint 3 and are unchanged.